# Room8

Datenschutz-Compliance-Bericht 2026

Umfassende Dokumentation der Verarbeitung personenbezogener Daten gemäß der Datenschutz-Grundverordnung (DSGVO, EU 2016/679), des Bundesdatenschutzgesetzes (BDSG) und des Telekommunikation-Telemedien-Datenschutz-Gesetzes (TTDSG).

Version 1.0 · Stand: 11. Mai 2026

Erstellt für die Bachelorarbeit-Präsentation Universität Augsburg

Verantwortlicher: Yusuf Albayrak (Room8 / Yumita)

## Inhaltsverzeichnis


1. Einleitung und Geltungsbereich
2. Verantwortlicher und Kontakt
3. Rechtsgrundlagen der Verarbeitung
4. Übersicht der verarbeiteten Datenkategorien
5. Verarbeitungszwecke im Detail
6. Empfänger und Auftragsverarbeiter
7. Drittlandsübermittlung (US-Datentransfer)
8. Aufbewahrungs- und Löschungsfristen
9. Cookies, lokaler Speicher und Tracking-Technologien
10. Push-Notifications
11. App-Berechtigungen (Kamera, Mikrofon, Standort)
12. Betroffenenrechte gemäß Art. 15–22 DSGVO
13. Technische und organisatorische Sicherheitsmaßnahmen
14. Spezielle Regelungen — Wohnungsplattform & Untervermietung
15. Spezielle Regelungen — Marktplatz, Jobs, Events, Coupons
16. Trust- und Sicherheits-Layer
17. Minderjährigenschutz
18. Beschwerderecht und zuständige Aufsichtsbehörde
19. Änderungen dieser Erklärung
20. Anhang A — Technologie-Stack
21. Anhang B — Auftragsverarbeitungsverträge (AVV-Status)
22. Anhang C — Datenschutz-Folgenabschätzung (DSFA)
23. Anhang D — Glossar und Abkürzungsverzeichnis

## 1. Einleitung und Geltungsbereich

Die vorliegende Datenschutz-Compliance-Dokumentation beschreibt umfassend, in welcher Art und Weise die Plattform **Room8** (im Folgenden: „Room8", „wir" oder „die Plattform") personenbezogene Daten ihrer Nutzerinnen und Nutzer erhebt, verarbeitet, speichert und gegebenenfalls an Dritte übermittelt.

Room8 ist eine bilinguale Plattform (Deutsch / Englisch) für Studierende, die folgende Funktionen anbietet:

- **Wohnungen:** Vermittlung von Wohngemeinschafts-Zimmern, Apartments und Untermiet-Angeboten zwischen Studierenden
- **Marktplatz:** An- und Verkauf von gebrauchten Gegenständen (Bücher, Möbel, Elektronik, Fahrräder)
- **Jobs:** Studi-Jobs, Werkstudenten-Stellen, Aushilfsjobs, Praktika
- **Events:** Studi-Partys, Pub-Quizzes, Workshops, Vorträge, Sport-Veranstaltungen
- **Coupons:** Studierenden-Rabatte bei lokalen Partner-Geschäften (Cafés, Bars, Geschäfte, Dienstleister)
- **Chat:** Direkt-Nachrichten zwischen Nutzern auf Basis eines konkreten Inserats
- **Trust-Layer:** Studi-Verifizierung, Block- und Melde-Funktionen, Bewertungen

Die Plattform ist über eine Web-Anwendung ( `www.room8.club` ) sowie über native Apps für Apple iOS (App Store) und Google Android (Play Store) zugänglich. Die Datenschutzerklärung gilt für sämtliche Zugangswege gleichermaßen.

*Rechtsgrundlage dieser Dokumentation: Verordnung (EU) 2016/679 (Datenschutz-Grundverordnung, „DSGVO"), Bundesdatenschutzgesetz (BDSG), Telekommunikation-Telemedien-Datenschutz-Gesetz (TTDSG), § 13 Telemediengesetz (TMG).*

## 2. Verantwortlicher und Kontakt

Verantwortlich für die Datenverarbeitung im Sinne von Art. 4 Nr. 7 DSGVO ist:

| | |
|---|---|
| **Verantwortlicher** | Yusuf Albayrak (handelnd unter „Room8" / „Yumita") |
| **Anschrift** | Kamelweg 6, 86381 Krumbach, Deutschland |
| **E-Mail (allgemein)** | info@room8.club |
| **E-Mail (Datenschutzanfragen)** | privacy@room8.club |
| **Telefon** | auf Anfrage |

| | |
|---|---|
| **Webseite** | https://www.room8.club |
| **Datenschutzbeauftragter** | Aufgrund der Unternehmensgröße ist gemäß Art. 37 DSGVO i. V. m. § 38 BDSG kein Datenschutzbeauftragter zwingend zu benennen. Datenschutzanfragen werden direkt vom Verantwortlichen bearbeitet. |

## 3. Rechtsgrundlagen der Verarbeitung

Sämtliche Verarbeitungen personenbezogener Daten auf der Plattform Room8 erfolgen ausschließlich auf einer der nachfolgend aufgeführten Rechtsgrundlagen. Die jeweilige Rechtsgrundlage wird in den weiteren Abschnitten dieses Dokuments für jeden Verarbeitungszweck konkret benannt.

| Artikel | Anwendungsfall |
|---|---|
| **Art. 6 Abs. 1 lit. a DSGVO**<br>*Einwilligung* | Versand von Push-Benachrichtigungen, Setzen nicht-essenzieller Cookies, optionale Marketing-E-Mails, Verarbeitung von Standortinformationen jenseits der angegebenen Stadt. |
| **Art. 6 Abs. 1 lit. b DSGVO**<br>*Vertragserfüllung* | Bereitstellung sämtlicher Plattform-Kernfunktionen: Registrierung, Profilverwaltung, Veröffentlichung von Inseraten, Chat zwischen Nutzern, Coupon-Einlösung. |
| **Art. 6 Abs. 1 lit. c DSGVO**<br>*Rechtliche Verpflichtung* | Aufbewahrung von Rechnungen und steuerrelevanten Belegen (HGB, AO), Auskunftspflichten gegenüber Strafverfolgungsbehörden, Meldepflichten nach Telemediengesetz. |
| **Art. 6 Abs. 1 lit. f DSGVO**<br>*Berechtigte Interessen* | Schutz der Plattform vor Missbrauch, Fehlerprotokollierung (Sentry), Rate-Limiting, Block- und Melde-Funktionen, statistische Auswertung in aggregierter Form. |

## 4. Übersicht der verarbeiteten Datenkategorien

### 4.1 Registrierungsdaten

| Datum | Zweck | Rechtsgrundlage |
|---|---|---|
| E-Mail-Adresse | Eindeutige Identifikation, Account-Wiederherstellung, sicherheitsrelevante Mitteilungen | Art. 6 I lit. b |
| Passwort (gehashed via bcrypt/Argon2) | Authentifizierung | Art. 6 I lit. b |
| Nutzername | Anzeige in Inseraten und Chat | Art. 6 I lit. b |

| | | |
|---|---|---|
| Vor- und Nachname (optional) | Höflichkeit, Verifizierung gegenüber anderen Nutzern | Art. 6 I lit. b |
| Studi-Mail-Adresse oder Immatrikulationsnachweis (optional, Verifizierung) | Erhöhung des Trust-Levels (Student-Verified-Badge) | Art. 6 I lit. a |
| Geburtsdatum (optional) | Altersverifikation, ggf. Anbieten zielgruppenspezifischer Coupons | Art. 6 I lit. a |

### 4.2 Profildaten

- Profilbild (optional, vom Nutzer selbst hochgeladen, gespeichert in Supabase-Storage-Bucket `avatars`)
- Stadt (Pflichtangabe für City-basierte Benachrichtigungen und Listing-Sichtbarkeit)
- Bio / Selbstbeschreibung (optional)
- Studiengang und Hochschule (optional)
- Sprachpräferenz (Deutsch / Englisch)
- Notification-Einstellungen (Push-Toggles pro Kategorie, Quiet-Hours)

### 4.3 Listing-Daten

Für jedes vom Nutzer veröffentlichte Inserat werden je nach Kategorie folgende Daten verarbeitet:

- **Wohnungen:** Titel, Beschreibung, Stadt, Bezirk, Adresse (optional), Miete, Nebenkosten (optional), Zimmertyp, Verfügbarkeitsdatum, Fotos, Möblierung
- **Marktplatz:** Titel, Beschreibung, Stadt, Preis, Zustand, Fotos, Kategorie
- **Jobs:** Firmenname, Stellenbeschreibung, Anforderungen, Benefits, Vergütung, Arbeitszeit, Bewerbungs-E-Mail/-URL
- **Events:** Titel, Beschreibung, Ort, Adresse, Startzeitpunkt, Endzeitpunkt, maximale Teilnehmerzahl, Preis, Cover-Bild
- **Coupons:** Geschäftsname, Adresse, Telefonnummer, Webseite, Instagram-Handle, Öffnungszeiten, Rabatt-Wert, Einlöse-Bedingungen

### 4.4 Kommunikationsdaten

- **Chat-Nachrichten:** Sender-ID, Empfänger-ID, Listing-ID (Bezug), Textinhalt, Zeitstempel, Gelesen-Status
- **Bewertungen:** Reviewer-ID, Reviewed-ID, Listing-ID, Sterne-Bewertung, Kommentar, Zeitstempel
- **Reports:** Reporter-ID (anonymisiert nach Verarbeitung), gemeldeter Content/User, Grund, Zeitstempel
- **Coupon-Einlösungen:** User-ID, Coupon-ID, Partner-ID, Zeitstempel, Bestätigungs-Code

### 4.5 Technische Daten

- **FCM-Tokens** (Firebase Cloud Messaging): gerätespezifische Token zur Zustellung von Push-Benachrichtigungen, gespeichert pro Gerät, automatisch invalidiert bei Token-Rotation
- **IP-Adressen:** in Server-Logs für maximal 30 Tage zur Missbrauchsabwehr (anonymisiert nach 7 Tagen)
- **Browser- und Geräteinformationen:** User-Agent, Betriebssystem, App-Version
- **Authentifizierungs-Tokens (JWT):** Session-Verwaltung, gespeichert im lokalen Speicher des Endgeräts (LocalStorage / Keychain)
- **Fehlerprotokolle (Sentry):** Stack-Traces bei Abstürzen, ohne personenbezogene Daten (E-Mails und Tokens werden via `beforeSend`-Filter entfernt)

### 4.6 Standortdaten

Room8 verarbeitet **keine präzisen GPS-Koordinaten**. Die Stadt-Information ist eine vom Nutzer aktiv eingegebene Angabe. Es findet kein passives Tracking des aktuellen Aufenthaltsorts statt. Standortbasierte Benachrichtigungen („Neue Wohnung in Augsburg") basieren ausschließlich auf der vom Nutzer angegebenen Heimatstadt.

## 5. Verarbeitungszwecke im Detail

### 5.1 Account-Verwaltung

Die Anmeldung erfolgt entweder mittels E-Mail/Passwort, Apple Sign-In oder Google Sign-In. Wir verwenden bei OAuth-Anbietern ausschließlich Standard-Scopes (`email`, `profile`) und speichern keine zusätzlichen Informationen vom Identity-Provider außer dem Klarnamen und der E-Mail.

### 5.2 Listing-Veröffentlichung

Vom Nutzer veröffentlichte Inserate sind innerhalb der Plattform öffentlich sichtbar. Adressen und Telefonnummern sind nur sichtbar, wenn der Nutzer sie aktiv ins Inserat aufnimmt — eine technische Erkennung oder Vorbefüllung erfolgt nicht.

### 5.3 Chat zwischen Nutzern

Chat-Nachrichten werden Ende-zu-Ende auf Plattform-Ebene gespeichert (nicht verschlüsselt vom Anbieter — der Plattformbetreiber hat theoretisch Lese-Zugriff zur Missbrauchsabwehr). Sender und Empfänger sehen jeweils ihre Nachrichten, dritte Nutzer haben keinen Zugriff. Bei einem Konto-Löschauftrag werden alle Nachrichten, an denen der Account beteiligt war, gelöscht.

## 5.4 Coupon-Einlösung

Beim Einlösen eines Coupons wird ein QR-Code generiert, der nur den Coupon-Identifier und einen kurzlebigen Bestätigungs-Code enthält. Der Partner scannt diesen Code in der separaten Partner-Web-App und bestätigt die Einlösung. Eine Übermittlung weiterer personenbezogener Daten an den Partner findet nicht statt.

## 5.5 Trust-Layer und Missbrauchsabwehr

Zur Wahrung der Sicherheit der Plattform werden folgende Funktionen bereitgestellt:

- **Block-Funktion:** Nutzer können andere Nutzer blockieren. Geblockte Nutzer können den Blockierenden in keinem Inserat sehen, keine Nachrichten senden und keine Bewertungen abgeben.
- **Report-Funktion:** Verstöße können gemeldet werden. Reports werden anonym an die Administration übermittelt und nach Bearbeitung pseudonymisiert.
- **Rate-Limiting:** Übermäßige Aktivität (mehr als 5 Reports pro Stunde, mehr als 30 pro Tag) wird automatisch geblockt.
- **Studi-Verifikation:** Optionale Hochladen von Studi-Ausweis oder Immatrikulationsbescheinigung erhöht das Trust-Level.

## 6. Empfänger und Auftragsverarbeiter

Room8 bedient sich folgender externer Dienstleister im Rahmen der Auftragsverarbeitung gemäß Art. 28 DSGVO. Mit allen genannten Auftragsverarbeitern wurden Auftragsverarbeitungsverträge (Data Processing Agreements / DPAs) geschlossen.

### 6.1 Supabase (Datenbank, Authentifizierung, Storage)

| | |
|---|---|
| **Anbieter** | Supabase Inc., 970 Toa Payoh North #07-04, Singapur 318992 |
| **Verarbeitete Daten** | Sämtliche Plattform-Datenbank-Inhalte (User-Accounts, Listings, Chat, Bewertungen, Bilder), Authentifizierung-Sessions |
| **Server-Standort** | EU-Region (Frankfurt am Main, Deutschland) |
| **DPA** | **Vorhanden** Supabase Data Processing Agreement, Stand 2024 |
| **Rechtsgrundlage** | Art. 28 DSGVO i. V. m. Art. 6 I lit. b |
| **Zweck** | Bereitstellung der Datenbank-Infrastruktur, Authentifizierung, Datei-Speicherung |

### 6.2 Firebase Cloud Messaging (Push-Benachrichtigungen)

| | |
|---|---|
| **Anbieter** | Google Ireland Limited, Gordon House, Barrow Street, Dublin 4, Irland (Google Cloud) |
| **Verarbeitete Daten** | FCM-Device-Tokens (gerätespezifisch, keine Klaridentifier), Push-Payload (Titel, Body, URL) |
| **Server-Standort** | Global (Google Cloud, EU-Sub-Processor in Belgien/Niederlande verfügbar) |
| **DPA** | **Vorhanden** Google Cloud Data Processing Addendum, EU-Standardvertragsklauseln |
| **Rechtsgrundlage** | Art. 6 I lit. a DSGVO (Einwilligung) — die User stimmt Push-Benachrichtigungen über den Native-Permission-Dialog des Betriebssystems aktiv zu |
| **Zweck** | Zustellung von Push-Benachrichtigungen über das jeweilige Betriebssystem |

### 6.3 Vercel (Web-Hosting)

| | |
|---|---|
| **Anbieter** | Vercel Inc., 440 N Barranca Avenue #4133, Covina, CA 91723, USA |
| **Verarbeitete Daten** | Server-Logs (IP-Adresse, User-Agent, angefragte URL, Zeitstempel, Response-Code) |
| **Server-Standort** | Edge-Netzwerk (EU-Region `fra1` Frankfurt für Web-Traffic aus DACH) |
| **DPA** | **Vorhanden** Vercel Data Processing Addendum, EU-Standardvertragsklauseln |
| **Rechtsgrundlage** | Art. 6 I lit. f DSGVO (berechtigtes Interesse — Bereitstellung der Web-Anwendung) |
| **Zweck** | Hosting der Web-Anwendung, Auslieferung statischer Assets |

### 6.4 Resend (transaktionale E-Mails)

| | |
|---|---|
| **Anbieter** | Resend, Inc., 2261 Market Street #4408, San Francisco, CA 94114, USA |
| **Verarbeitete Daten** | E-Mail-Adresse des Empfängers, Inhalt der E-Mail (Account-Bestätigung, Passwort-Reset, Benachrichtigungen) |
| **Server-Standort** | USA |
| **DPA** | **Zu prüfen** Resend Privacy & Security Page, EU-Standardvertragsklauseln in Erstellung |
| **Rechtsgrundlage** | Art. 6 I lit. b DSGVO (Vertragserfüllung) |
| **Zweck** | Versand transaktionaler E-Mails (Account-Bestätigung, Passwort-Reset, kritische Benachrichtigungen) |

### 6.5 Sentry (Fehlerprotokollierung)

| | |
|---|---|
| **Anbieter** | Functional Software, Inc. d/b/a Sentry, 45 Fremont Street, 8th Floor, San Francisco, CA 94105, USA |
| **Verarbeitete Daten** | Stack-Traces bei Abstürzen, Browser-User-Agent, Plattform-Version |
| **Konfiguration** | PII-Filter aktiv (E-Mails, Access-Tokens, Refresh-Tokens werden via `beforeSend` entfernt), Trace-Sample-Rate 0, Session-Replay-Sample-Rate 0 |
| **Server-Standort** | EU-Region (Frankfurt am Main) |

| | |
|---|---|
| **DPA** | **Vorhanden** Sentry Data Processing Agreement |
| **Rechtsgrundlage** | Art. 6 I lit. f DSGVO (berechtigtes Interesse — Fehlerdiagnose und Stabilität) |

### 6.6 Apple (App Store Distribution, Sign-In)

| | |
|---|---|
| **Anbieter** | Apple Inc. / Apple Distribution International, Hollyhill Industrial Estate, Hollyhill, Cork, Irland |
| **Verarbeitete Daten** | Bei Sign-In: Apple-ID-spezifische E-Mail (auf Wunsch des Users auch private Relay-Adresse), Klarname |
| **DPA** | **Vorhanden** Apple Developer Program License Agreement |
| **Rechtsgrundlage** | Art. 6 I lit. b DSGVO |

### 6.7 Google (Play Store Distribution, Sign-In)

| | |
|---|---|
| **Anbieter** | Google Ireland Limited, Gordon House, Barrow Street, Dublin 4, Irland |
| **Verarbeitete Daten** | Bei Sign-In: Google-Account-E-Mail, Klarname, Profilbild-URL |
| **DPA** | **Vorhanden** Google Cloud Data Processing Addendum |
| **Rechtsgrundlage** | Art. 6 I lit. b DSGVO |

## 7. Drittlandsübermittlung (US-Datentransfer)

Sofern personenbezogene Daten in die USA übermittelt werden (insbesondere bei Vercel, Resend und Sentry mit Backup-Region USA), erfolgt dies auf Basis der folgenden Rechtsgrundlagen:

- **EU-US Data Privacy Framework (DPF):** Ergänzend zur DSGVO bestätigt seit Juli 2023, dass zertifizierte US-Unternehmen ein angemessenes Schutzniveau gewährleisten. Wir bevorzugen DPF-zertifizierte Anbieter.
- **EU-Standardvertragsklauseln (SCC):** Mit allen US-Auftragsverarbeitern wurden die EU-Standardvertragsklauseln (Module 2 — Verantwortlicher zu Auftragsverarbeiter) gemäß Beschluss der Europäischen Kommission 2021/914 abgeschlossen.
- **Zusätzliche technische Maßnahmen:** Transport-Verschlüsselung (TLS 1.3), Verschlüsselung at-rest (AES-256), pseudonymisierte Identifier, beschränkte Zugriffsrechte.

> **Hinweis zur Risikobewertung:** Nutzer werden ausdrücklich darauf hingewiesen, dass trotz aller Schutzmaßnahmen ein Restrisiko bei der Übermittlung in die USA besteht, insbesondere aufgrund weitreichender Zugriffsbefugnisse amerikanischer Geheimdienste (FISA Sec. 702, Executive Order 12333). Sollten Nutzer dieses Risiko vermeiden wollen, können sie alternativ ausschließlich die Web-Anwendung verwenden, die auf EU-Servern gehostet ist, und auf Apple/Google-Sign-In sowie Push-Benachrichtigungen verzichten.

## 8. Aufbewahrungs- und Löschungsfristen

| Datenkategorie | Aufbewahrungsdauer | Rechtsgrundlage |
|---|---|---|
| Account-Daten | So lange der Account aktiv ist + 30 Tage Karenz nach Löschauftrag | Art. 17 DSGVO |
| Inseratsdaten | So lange das Inserat aktiv ist; nach Deaktivierung 90 Tage | Art. 6 I lit. b |
| Chat-Nachrichten | So lange beide Gesprächspartner aktiv sind | Art. 6 I lit. b |
| Server-Logs (IP, User-Agent) | 30 Tage, IP-anonymisiert nach 7 Tagen | Art. 6 I lit. f |
| Fehlerprotokolle (Sentry) | 90 Tage rollend | Art. 6 I lit. f |
| Push-Notification-Logs | 30 Tage zu statistischen Zwecken | Art. 6 I lit. f |
| Reports und Moderations-Aktionen | 3 Jahre (Beweismittel bei wiederkehrendem Missbrauch) | Art. 6 I lit. f |

| | | |
|---|---|---|
| Steuerlich relevante Belege | 10 Jahre gemäß § 257 HGB, § 147 AO | Art. 6 I lit. c |

## 9. Cookies, lokaler Speicher und Tracking-Technologien

Room8 unterscheidet strikt zwischen technisch notwendigen und nicht-notwendigen Speicher-Technologien. Nicht-notwendige Cookies werden ausschließlich nach ausdrücklicher Einwilligung des Nutzers gesetzt (Opt-In gemäß § 25 Abs. 1 TTDSG).

### 9.1 Technisch notwendige Speicher-Inhalte

Diese sind essenziell für den Betrieb der Plattform und werden ohne Einwilligung gesetzt (Rechtsgrundlage: § 25 Abs. 2 Nr. 2 TTDSG, Art. 6 I lit. b DSGVO):

| Name / Schlüssel | Speicherort | Zweck | Speicherdauer |
|---|---|---|---|
| `sb-tvnvmogaqmduzcycmvby-auth-token` | LocalStorage | Authentifizierungs-Token (JWT) | 1 Stunde (Auto-Refresh) |
| `room8_language` | LocalStorage | Spracheinstellung (de / en) | persistent |
| `room8_user_id` | SessionStorage | Caching der User-ID innerhalb einer Session | Tab-Lebensdauer |
| `room8_pwa_dismissed` | LocalStorage | Speichert, ob der PWA-Install-Hinweis bereits weggeklickt wurde | persistent |

### 9.2 Nicht-notwendige Cookies und Speicher-Inhalte (Opt-In)

Diese werden ausschließlich nach aktiver Zustimmung über das Cookie-Banner gesetzt:

| Name | Anbieter | Zweck | Speicherdauer |
|---|---|---|---|
| Sentry Session-ID | Sentry | Fehlerprotokollierung und Performance-Monitoring | Tab-Session |
| Push-Notification-Token | Firebase | Geräte-Identifikation für Push-Zustellung | persistent, bis Token-Rotation |

### 9.3 Cookie-Banner und Widerruf

Beim ersten Besuch der Web-Anwendung wird ein Cookie-Banner angezeigt, das eine differenzierte Auswahl ermöglicht (Alle akzeptieren / Nur notwendige / Einzeln auswählen). Die Auswahl kann jederzeit über den Link *„Cookie-Einstellungen ändern"* im Footer angepasst werden. Ein einmal

erteilter Widerruf gilt sofort und führt zur unverzüglichen Löschung der entsprechenden Speicher-Inhalte.

## 10. Push-Notifications

Push-Benachrichtigungen werden ausschließlich nach aktiver Zustimmung des Nutzers über den nativen Permission-Dialog des Betriebssystems (iOS, Android) bzw. der Web Push API zugestellt. Eine vorherige Einwilligung ist Voraussetzung (Art. 6 I lit. a DSGVO).

Im Detail werden folgende Benachrichtigungs-Kategorien unterschieden, die individuell in den Notification-Einstellungen aktiviert oder deaktiviert werden können:

- **Chat-Nachrichten:** Neue Nachricht zu einem Inserat
- **City-Listings:** Neue Wohnung / Job / Coupon in deiner Stadt
- **Favoriten:** Jemand hat dein Inserat favorisiert
- **Bewertungen:** Du hast eine neue Bewertung erhalten
- **Bewerbungen:** Jemand interessiert sich für deinen Job
- **Coupon-Einlösungen:** Real-time Bestätigung beim Partner-Scan
- **System-Nachrichten:** Wichtige Sicherheits- und Servicemitteilungen

Quiet-Hours können konfiguriert werden (Standard: 22:00–07:00 Uhr werden keine Push-Benachrichtigungen zugestellt, kritische System-Nachrichten ausgenommen).

## 11. App-Berechtigungen (Kamera, Mikrofon, Standort)

| Berechtigung | Verwendung | Pflicht oder optional? |
|---|---|---|
| Kamera | Aufnahme von Profilbildern und Inserats-Fotos | Optional |
| Foto-Bibliothek | Auswahl bestehender Bilder als Profilbild oder Inserat | Optional |
| Push-Notifications | Zustellung von Benachrichtigungen | Optional |
| Standort (präzise) | Nicht angefragt — wird nicht verarbeitet | Nicht aktiv |
| Mikrofon | Nicht angefragt | Nicht aktiv |
| Kontakte | Nicht angefragt | Nicht aktiv |
| Kalender | Nicht angefragt | Nicht aktiv |

## 12. Betroffenenrechte gemäß Art. 15–22 DSGVO

Sämtliche Nutzer haben gegenüber Room8 folgende Rechte hinsichtlich ihrer personenbezogenen Daten:

### 12.1 Recht auf Auskunft (Art. 15 DSGVO)

Nutzer können jederzeit eine Auskunft über sämtliche zu ihrer Person gespeicherten Daten anfordern. Eine entsprechende Anfrage ist an `privacy@room8.club` zu richten. Die Auskunft erfolgt binnen 30 Tagen (Art. 12 Abs. 3 DSGVO).

### 12.2 Recht auf Berichtigung (Art. 16 DSGVO)

Unrichtige oder unvollständige Daten können in den Profil-Einstellungen direkt korrigiert werden.

### 12.3 Recht auf Löschung („Recht auf Vergessenwerden", Art. 17 DSGVO)

Über die Option *„Konto löschen"* in den Einstellungen löscht der Nutzer seinen vollständigen Account inklusive sämtlicher von ihm veröffentlichter Inserate, Bilder, Chat-Nachrichten und Bewertungen. Der Vorgang ist unmittelbar und endgültig nach einer Karenz von 30 Tagen.

Technisch geschieht dies in folgenden Schritten:

1. Löschung aller User-eigenen Storage-Objekte (Profilbild, Listing-Fotos, Chat-Anhänge)
2. Löschung sämtlicher Datenbank-Datensätze (Listings, Messages, Reviews, Reports, Saved Searches, Events, Coupons, FCM-Tokens, Notifications, Favorites, Profile-Eintrag)
3. Löschung des Authentifizierungs-Records via Server-seitiger Edge-Function `delete-user`, welche `auth.admin.deleteUser()` aufruft
4. Bestätigung an den Nutzer per E-Mail

Backup-Kopien werden im Rolling-Window von 7 Tagen vorgehalten und nach Ablauf automatisch überschrieben.

### 12.4 Recht auf Einschränkung der Verarbeitung (Art. 18 DSGVO)

Auf Antrag wird die Verarbeitung bestimmter Daten eingeschränkt, beispielsweise während einer laufenden Beschwerde-Prüfung.

### 12.5 Recht auf Datenübertragbarkeit (Art. 20 DSGVO)

Nutzer können ihre Daten in einem strukturierten, gängigen und maschinenlesbaren Format (JSON) erhalten. Eine entsprechende Export-Funktion ist in den Einstellungen verfügbar (Roadmap: Phase 2 nach Demo).

### 12.6 Widerspruchsrecht (Art. 21 DSGVO)

Gegen Verarbeitungen auf Basis von Art. 6 I lit. f DSGVO (berechtigte Interessen) kann jederzeit Widerspruch eingelegt werden.

### 12.7 Recht auf Beschwerde bei der Aufsichtsbehörde (Art. 77 DSGVO)

Nutzer haben das Recht, sich bei einer Datenschutz-Aufsichtsbehörde zu beschweren. Zuständig ist:

> **Bayerisches Landesamt für Datenschutzaufsicht (BayLDA)**
> Promenade 18, 91522 Ansbach
> Telefon: +49 (0) 981 180093-0
> E-Mail: poststelle@lda.bayern.de
> Webseite: https://www.lda.bayern.de

## 13. Technische und organisatorische Sicherheitsmaßnahmen (TOMs)

Gemäß Art. 32 DSGVO haben wir geeignete technische und organisatorische Maßnahmen ergriffen, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten. Im Einzelnen:

### 13.1 Vertraulichkeit

- Row Level Security (RLS) auf sämtlichen Datenbank-Tabellen — User können nur eigene Datensätze sehen / verändern
- Passwörter werden mittels bcrypt (Cost-Factor 12) gehashed gespeichert; Klartext-Passwörter werden zu keinem Zeitpunkt persistiert
- JWT-Tokens haben eine Lebensdauer von maximal 1 Stunde, Refresh-Tokens werden bei jeder Verwendung rotiert
- Zugriffsrechte auf Storage-Buckets sind per Policy auf den jeweiligen Eigentümer beschränkt
- Service-Role-Keys werden ausschließlich serverseitig in Edge-Functions verwendet, niemals an den Client ausgeliefert

### 13.2 Integrität

- Datenbank-Integritäts-Constraints (Foreign-Keys, Check-Constraints, NOT-NULL)
- Kryptografische Hash-Verifizierung bei Storage-Uploads
- Audit-Logs für administrative Aktionen

### 13.3 Verfügbarkeit

- Automatische tägliche Backups der Datenbank (Point-in-Time-Recovery für 7 Tage)
- Daily Health-Check via Cron auf Notification-Pipeline
- Sentry-Monitoring auf Anomalien
- CDN-basiertes Hosting mit globaler Verfügbarkeit

### 13.4 Transport-Verschlüsselung

- TLS 1.3 für sämtliche Web-Requests (HTTPS-only, HSTS-Header gesetzt)
- Certificate-Pinning auf nativen Apps gegen Man-in-the-Middle-Angriffe

### 13.5 Verschlüsselung at-rest

- Datenbank: AES-256 Encryption auf Storage-Volume-Level
- Storage-Buckets: Server-Side-Encryption

- Backups: AES-256-Verschlüsselung mit Anbieter-managed-Keys

### 13.6 Trust-Layer-Mechanismen

- Block-Funktion bidirektional, RLS-enforced
- Report-Funktion mit Anti-Trolling-Rate-Limits (5/h, 30/d)
- Studi-Verifikation als optionales Trust-Boost-Feature

## 14. Spezielle Regelungen — Wohnungs-Plattform und Untervermietung

> **Wichtiger Haftungsausschluss:** Room8 ist ausschließlich eine technische Vermittlungs-Plattform und tritt nicht als Vertragspartei zwischen Vermieter und Mieter / Untermieter auf. Sämtliche rechtlichen, finanziellen und faktischen Konsequenzen einer Wohnungsvermietung oder -untervermietung liegen ausschließlich bei den jeweiligen Nutzern.

### 14.1 Stellung von Room8

Room8 stellt eine Plattform zur Verfügung, auf der Studierende Wohnungs-Inserate veröffentlichen und Interessenten kontaktieren können. Room8 ist kein Makler im Sinne des § 652 BGB, kein Vermieter und kein Mietvertragspartner. Es findet zu keinem Zeitpunkt eine Prüfung, Validierung oder Empfehlung der angebotenen Wohnungen durch Room8 statt.

### 14.2 Verantwortlichkeit der Nutzer

Die inserierende Person (Vermieter oder Untervermieter) ist allein und vollumfänglich verantwortlich für:

- Die rechtliche Berechtigung zur Untervermietung (Zustimmung des Hauptvermieters nach § 540 BGB)
- Die korrekte Angabe von Miete, Nebenkosten, Kaution und sonstigen Kosten
- Die Einhaltung mietrechtlicher Vorgaben (insbesondere Mietpreisbremse, ortsübliche Vergleichsmiete, Wohnflächenangabe)
- Die Einhaltung der Wohnraum-Zweckentfremdungsverordnung der jeweiligen Stadt
- Die korrekte Abführung von Einkommensteuer auf Mieteinnahmen
- Die Beachtung des Mieterschutzes (Kündigungsfristen, Mietminderungsrechte, etc.)

### 14.3 Untervermietung — gesetzliche Pflichten

Untervermietungen sind in Deutschland nur unter bestimmten Voraussetzungen zulässig. Die folgenden Punkte gelten als allgemeine Hinweise, ersetzen jedoch ausdrücklich keine Rechtsberatung:

- **Erlaubnis des Hauptvermieters:** Eine Untervermietung ist gemäß § 540 BGB grundsätzlich nur mit Zustimmung des Hauptvermieters zulässig. Bei „berechtigtem Interesse" (z. B. Auslandssemester) hat der Hauptmieter einen Anspruch auf Erlaubnis (§ 553 BGB), doch dieser muss aktiv eingeholt werden.
- **Zweckentfremdung:** In vielen Großstädten (München, Berlin, Hamburg, Frankfurt) gibt es Zweckentfremdungsverbote — eine kommerzielle Kurzzeit-Untervermietung kann ein Bußgeld nach sich ziehen.
- **Steuerpflicht:** Mieteinnahmen sind grundsätzlich einkommensteuerpflichtig. Bagatell-Grenzen (z. B. 520 € pro Jahr nach altem Recht) wurden in jüngeren Reformen zum Teil angehoben — der jeweils aktuelle Stand ist beim Finanzamt zu erfragen.
- **Anmeldepflicht:** Untermieter müssen sich gemäß Bundesmeldegesetz (§ 17) bei der Gemeinde innerhalb von zwei Wochen anmelden.
- **Versicherung:** Die Hausratversicherung des Hauptmieters deckt in vielen Fällen nicht die Sachen des Untermieters ab.

## 14.4 Keine Haftung für Inhalte und Schäden

Room8 übernimmt keinerlei Haftung für:

- Die Richtigkeit der Angaben in einem Inserat (Wohnungsgröße, Bilder, Miete)
- Die rechtliche Zulässigkeit der angebotenen Untervermietung
- Vermögensschäden durch Vertragsbruch oder Betrug seitens eines anderen Nutzers
- Bauliche Mängel oder gesundheitliche Beeinträchtigungen in der vermieteten Immobilie
- Konflikte zwischen Haupt- und Untermieter
- Strafrechtliche, ordnungsrechtliche oder steuerrechtliche Konsequenzen einer Vermietung

Dies entspricht der Stellung als reine Hosting-Plattform gemäß § 7 Abs. 1 Telemediengesetz. Eine Pflicht zur aktiven Überwachung der eingestellten Inhalte besteht für Room8 nicht (§ 7 Abs. 2 TMG, Art. 14 ECRL).

## 14.5 Empfehlungen an die Nutzer

Wir empfehlen jedem Nutzer dringend, vor Abschluss eines Untermietvertrags:

1. Eine schriftliche Erlaubnis des Hauptvermieters einzuholen
2. Einen schriftlichen Untermietvertrag aufzusetzen (Mustervorlagen u. a. beim Deutschen Mieterbund verfügbar)
3. Die Wohnung persönlich zu besichtigen
4. Identität des Vertragspartners zu verifizieren (Personalausweis, Studi-Ausweis)
5. Kaution erst nach Schlüsselübergabe und gegen Quittung zu zahlen
6. Übergabeprotokoll mit Fotos zu erstellen
7. Sich beim Einwohnermeldeamt anzumelden

8. Bei rechtlichen Zweifeln einen Mietrechtsanwalt oder Mieterverein zu konsultieren

## 15. Spezielle Regelungen — Marktplatz, Jobs, Events, Coupons

### 15.1 Marktplatz

Room8 ist auch im Marktplatz kein Vertragspartner zwischen Verkäufer und Käufer. Gewährleistungsrechte gelten allein zwischen den vertragschließenden Privatpersonen. Bei gewerblicher Tätigkeit (mehr als gelegentliche Verkäufe) müssen die Nutzer eigenständig die Vorgaben zur Fernabsatz- und Verbraucherinformationspflicht (§ 312d BGB) sowie das Verbraucherrechtegesetz beachten.

### 15.2 Jobs

Job-Inserate werden ausschließlich vom inserierenden Arbeitgeber eingestellt. Die Verantwortung für die Einhaltung des Allgemeinen Gleichbehandlungsgesetzes (AGG), Mindestlohngesetzes (MiLoG), Arbeitszeitgesetzes (ArbZG) sowie Sozialversicherungspflichten liegt ausschließlich beim Arbeitgeber. Room8 prüft Inserate nicht inhaltlich.

### 15.3 Events

Veranstalter sind eigenverantwortlich für die Einhaltung der Versammlungs-, Gaststätten-, Lärmschutz- und Jugendschutzvorschriften. Bei Verkauf von Eintrittskarten oder Getränken können steuer- oder gewerberechtliche Pflichten entstehen.

### 15.4 Coupons

Coupon-Anbieter (Geschäfte, Restaurants, Bars) tragen die Verantwortung für die Einlösbarkeit, die rechtlich konforme Bewerbung (Preisangabenverordnung) und die korrekte steuerliche Behandlung gewährter Rabatte.

## 16. Trust- und Sicherheits-Layer

Zur Erhöhung der Sicherheit der Nutzer hat Room8 folgende Mechanismen implementiert:

| Funktion | Beschreibung | Status |
|---|---|---|
| Studi-Verifikation | Optionaler Upload Studi-Ausweis / Immatrikulationsbescheinigung — erhöht Trust-Badge | Live |
| Bidirektionaler Block | Geblockte User sehen keine Inserate, können keine Nachrichten senden | Live |
| Report-System | Inhalte und Profile melden; Anti-Trolling-Rate-Limit 5/h, 30/d | Live |

| | | |
|---|---|---|
| Bewertungs-System | Bewertungen nur nach echtem Kontakt (Chat-Nachweis erforderlich) | Live |
| Admin-Alerts | Push-Benachrichtigung an Admin bei Reports, Verdachts-Aktivitäten | Live |
| Stadt-Tippfehler-Schutz | Automatische Normalisierung gängiger Tippfehler (z. B. „Augsbrug" → „Augsburg") | Live |

## 17. Minderjährigenschutz

Room8 richtet sich primär an volljährige Studierende. Personen unter 16 Jahren dürfen die Plattform gemäß Art. 8 DSGVO grundsätzlich nicht eigenständig nutzen. Bei der Registrierung wird eine entsprechende Bestätigung abgefragt.

Bei Hinweisen auf eine Nutzung durch Minderjährige (etwa über Reports) wird das Konto unverzüglich gesperrt und nach Verifikation gelöscht. Die Verantwortung für die korrekte Altersangabe liegt beim Nutzer; eine technische Verifikation findet aufgrund datenschutzrechtlicher Verhältnismäßigkeit nicht statt.

## 18. Beschwerderecht und zuständige Aufsichtsbehörde

Unbeschadet anderer verwaltungsrechtlicher oder gerichtlicher Rechtsbehelfe steht jedem Betroffenen ein Beschwerderecht bei einer Aufsichtsbehörde zu, insbesondere in dem EU-Mitgliedstaat ihres Aufenthaltsorts, ihres Arbeitsplatzes oder des Orts des mutmaßlichen Verstoßes, wenn er der Ansicht ist, dass die Verarbeitung der ihn betreffenden personenbezogenen Daten gegen die DSGVO verstößt (Art. 77 DSGVO).

Für Room8 (Sitz in Krumbach, Bayern) ist zuständig:

> Bayerisches Landesamt für Datenschutzaufsicht (BayLDA)
> Promenade 18, 91522 Ansbach
> Telefon: +49 (0) 981 180093-0
> Telefax: +49 (0) 981 180093-800
> E-Mail: poststelle@lda.bayern.de
> Webseite: https://www.lda.bayern.de

## 19. Änderungen dieser Erklärung

Wir behalten uns vor, diese Datenschutz-Compliance-Dokumentation anzupassen, sofern sich die Rechtslage, unsere technischen Systeme oder unsere Datenverarbeitungs-Praktiken ändern. Bei wesentlichen Änderungen werden Nutzer per E-Mail oder im Rahmen der nächsten Plattform-Nutzung

aktiv informiert. Die jeweils aktuelle Version ist unter `https://www.room8.club/datenschutz.html` abrufbar.

## Anhang A — Technologie-Stack

| Komponente | Technologie | Anbieter | Hosting-Region |
|---|---|---|---|
| Datenbank | PostgreSQL 16 | Supabase | EU (Frankfurt) |
| Authentifizierung | Supabase Auth (JWT) | Supabase | EU (Frankfurt) |
| Object-Storage | Supabase Storage (S3-kompatibel) | Supabase | EU (Frankfurt) |
| Edge-Funktionen | Deno-Runtime | Supabase | EU (Frankfurt) |
| Web-Hosting | Vercel Edge Network | Vercel | EU (Frankfurt fra1) |
| Push-Benachrichtigungen | FCM HTTP v1 API | Google (Firebase) | EU / Global |
| Transaktional-E-Mails | Resend API | Resend | USA |
| Fehlerprotokollierung | Sentry SDK + Server | Functional Software, Inc. | EU (Frankfurt) |
| iOS-Distribution | App Store Connect | Apple Distribution International | EU (Cork, Irland) |
| Android-Distribution | Google Play Console | Google Ireland Limited | EU (Dublin) |
| Frontend-Framework | HTML / CSS / JavaScript (Capacitor 7) | Ionic / Eigenentwicklung | n/a |

## Anhang B — Auftragsverarbeitungsverträge (AVV-Status)

| Anbieter | AVV / DPA | SCC für US-Transfer | Status |
|---|---|---|---|
| Supabase | Supabase DPA, Version 2024 | n/a (EU-Hosting) | Vorhanden |
| Firebase / Google Cloud | Google Cloud Data Processing Addendum | EU-SCC Module 2 | Vorhanden |
| Vercel | Vercel DPA, Version 2024 | EU-SCC Module 2 | Vorhanden |

| | | | |
|---|---|---|---|
| Resend | Resend Privacy Page (DPA in Erstellung) | EU-SCC, DPF-Zertifizierung gewünscht | In Bearbeitung |
| Sentry | Sentry DPA, Version 2024 | EU-SCC Module 2 | Vorhanden |
| Apple Developer | Apple Developer Program License Agreement | EU-SCC (Apple Ireland) | Vorhanden |
| Google Play / Sign-In | Google Cloud Data Processing Addendum | EU-SCC Module 2 | Vorhanden |

## Anhang C — Datenschutz-Folgenabschätzung (DSFA)

Eine Datenschutz-Folgenabschätzung gemäß Art. 35 DSGVO ist erforderlich, wenn eine Verarbeitung „voraussichtlich ein hohes Risiko für die Rechte und Freiheiten natürlicher Personen zur Folge hat". Für Room8 wurde eine vorgelagerte Schwellwert-Analyse durchgeführt mit folgendem Ergebnis:

| Kriterium | Bewertung | Erläuterung |
|---|---|---|
| Systematische Bewertung persönlicher Aspekte | Niedrig | Match-Score basiert nur auf User-eigenen gespeicherten Suchen, kein Profiling |
| Verarbeitung besonderer Datenkategorien (Art. 9) | Keine | Keine Verarbeitung von Gesundheits-, biometrischen, religiösen oder politischen Daten |
| Systematische Überwachung öffentlicher Bereiche | Nein | n/a |
| Daten zu strafrechtlichen Verurteilungen | Keine | n/a |
| Datenverarbeitung in großem Umfang | Niedrig | Im Demo-Stadium < 1.000 User; Skalierungsgrenze 10.000 ohne erneute Bewertung |
| Datenkombination aus mehreren Quellen | Niedrig | Nur OAuth-Identity + selbst eingegebene Daten |
| Daten zu schutzbedürftigen Personen | Mittel | Studierende sind in Teilen Minderjährige (< 18, > 16) — gesonderter Schutz |
| Innovativer Einsatz neuer Technologien | Niedrig | Standard-Web-/Mobile-Stack, keine KI-basierte Entscheidungen |
| Daten-basierte Entscheidungen mit Rechtsfolge | Keine | Plattform ohne automatisierte Entscheidungen i. S. v. Art. 22 DSGVO |

**Ergebnis:** Eine vollständige Datenschutz-Folgenabschätzung gemäß Art. 35 DSGVO ist zum gegenwärtigen Stand nicht erforderlich. Bei einer Skalierung über 10.000 aktive Nutzer oder Einführung neuer Verarbeitungs-Funktionen (z. B. KI-basierte Match-Empfehlungen, Geo-Tracking) ist eine erneute Bewertung vorzunehmen.

## Anhang D — Glossar und Abkürzungsverzeichnis

| Begriff | Erläuterung |
|---|---|
| AGG | Allgemeines Gleichbehandlungsgesetz |
| AVV / DPA | Auftragsverarbeitungsvertrag / Data Processing Agreement |
| BayLDA | Bayerisches Landesamt für Datenschutzaufsicht |
| BDSG | Bundesdatenschutzgesetz |
| bcrypt | Kryptografische Hash-Funktion zur Passwort-Speicherung |
| DPF | EU-US Data Privacy Framework |
| DSFA | Datenschutz-Folgenabschätzung (Art. 35 DSGVO) |
| DSGVO | Datenschutz-Grundverordnung (EU 2016/679) |
| ECRL | E-Commerce-Richtlinie (RL 2000/31/EG) |
| FCM | Firebase Cloud Messaging (Push-Notification-Service) |
| JWT | JSON Web Token (Authentifizierungs-Format) |
| OAuth | Open Authorization Standard für externe Anmelde-Dienste |
| PII | Personally Identifiable Information (personenbezogene Daten) |
| RLS | Row Level Security (Zugriffsbeschränkung auf Datensatz-Ebene) |
| SCC | Standard Contractual Clauses (EU-Standardvertragsklauseln) |
| TMG | Telemediengesetz |
| TOMs | Technische und organisatorische Maßnahmen (Art. 32 DSGVO) |
| TTDSG | Telekommunikation-Telemedien-Datenschutz-Gesetz |